G I O I · BALI RESERVATION PLATFORM

QA E2E Browser Scenarios

apps/web (Nuxt) · apps/api (Fastify)

Customer · Host · Admin | 2026-11-08 | branch development

Overview

161 scenarios carry a status: **131** pass, **3** fail, **27** not run.

131	3	27	161
Passed	Failed	Not run	Scenarios

Manual (or Playwright-ready) browser scenarios for `apps/web` + `apps/api`.

Derived from the journey diagrams in `docs/diagrams/` (`customer-journey`, `host-journey`, `admin-journey`) and the code as of 2026-11-07. Run on a clean seeded database.

Priority: P0 = release blocker, P1 = must pass before launch, P2 = polish.

Status: Pass, Fail (link the bug), Not run.

0. Setup

Item	Value
Web	`http://localhost:3000` (Nuxt dev; `/api/**` proxies to `127.0.0.1:3001`)
API	`http://127.0.0.1:3001` (`pnpm --filter api dev`)
DB	Seeded (`pnpm --filter api prisma:seed`)
Super admin	`admin` / `password` (isSuperAdmin; manages Venues + Accounts in Settings; seed links it to the venue as `admin`)
Host	`host` / `password` (venue role `host`; confirm in Settings -> Accounts before testing)
Venue admin	create `venueadmin` in Settings -> Accounts as super admin (T-16): not super admin, venue role `admin`
Browsers	Desktop Chrome at 100%, plus mobile 390x844. Run the public booking flow (G-*) in both
Two-device tests	Two separate browser profiles (or normal + incognito)

Reset between runs: re-seed, or `TRUNCATE venues, users CASCADE` on the **test** DB only.

The DB integration tests must run against `gioi_test`. If `TEST_DATABASE_URL` is exported pointing at the dev DB they fail.

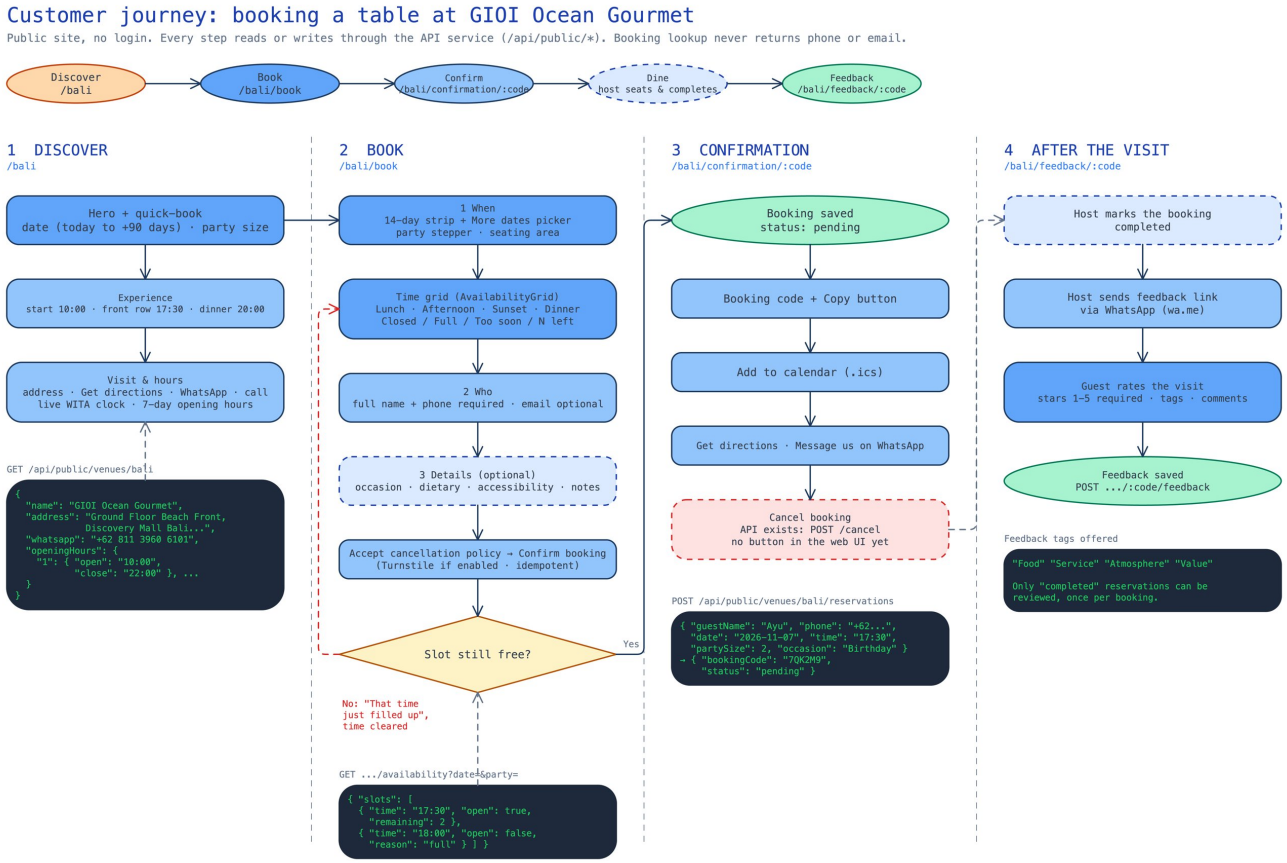
Diagram coverage map

Diagram stage	Scenarios
Customer 1 Discover `/bali`	G-01...G-03
Customer 2 Book `/bali/book`	G-04...G-15
Customer 3 Confirmation	G-16...G-21
Customer 4 Feedback	G-22...G-27
Host 1 Sign in	A-01...A-14
Host 2 Today's service + status machine	H-01...H-12
Host 3 Walk-in	W-01...W-06
Host 4 Guests	S-01...S-11
Admin 1 Sign in / role gate	A-02, A-03, R-*
Admin 2 Dashboard	D-01...D-12

Diagram stage	Scenarios
Admin 3 Settings (+ every save audited)	T-01...T-12
Audit log	L-01...L-06
Super admin venues & accounts	T-13...T-26, R-14
Bootstrap, prod, CI	B-01...B-06, D-13

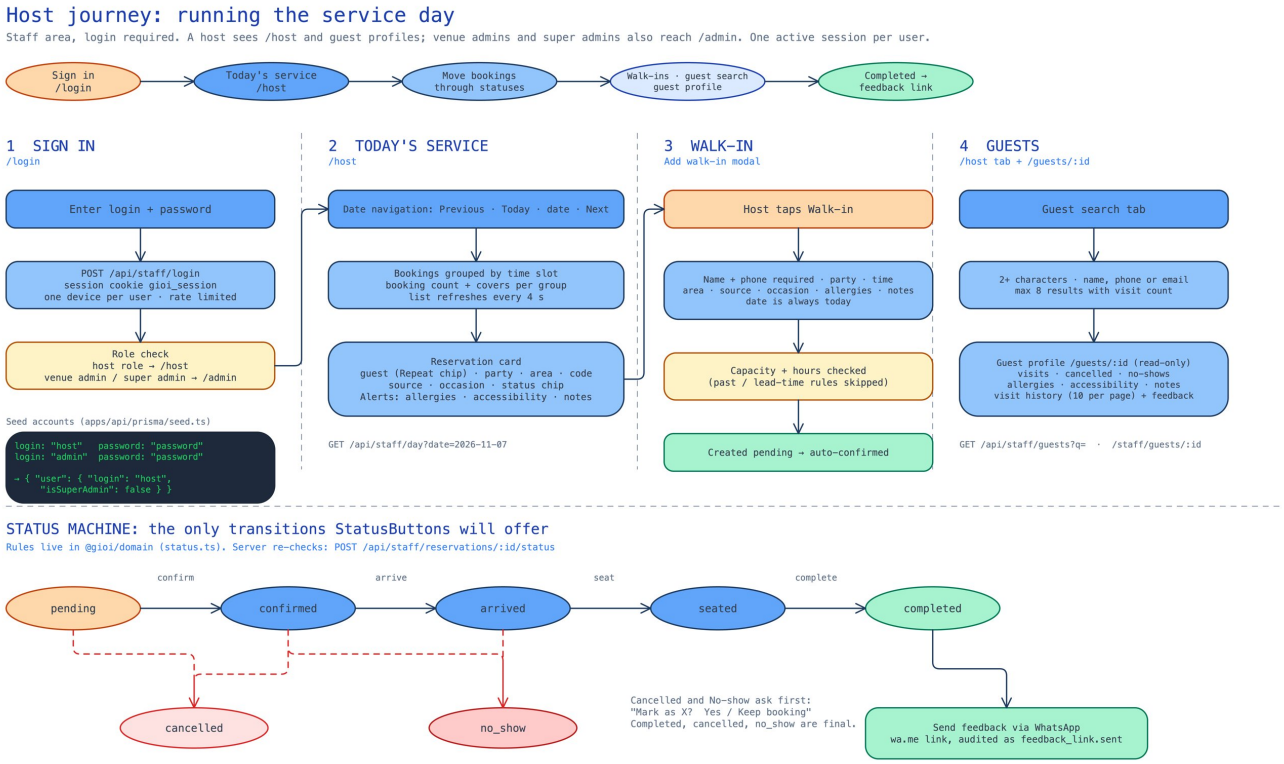
Customer journey

Source: docs/diagrams/customer-journey.excalidraw. Scenario IDs below map to these stages (see the coverage map).



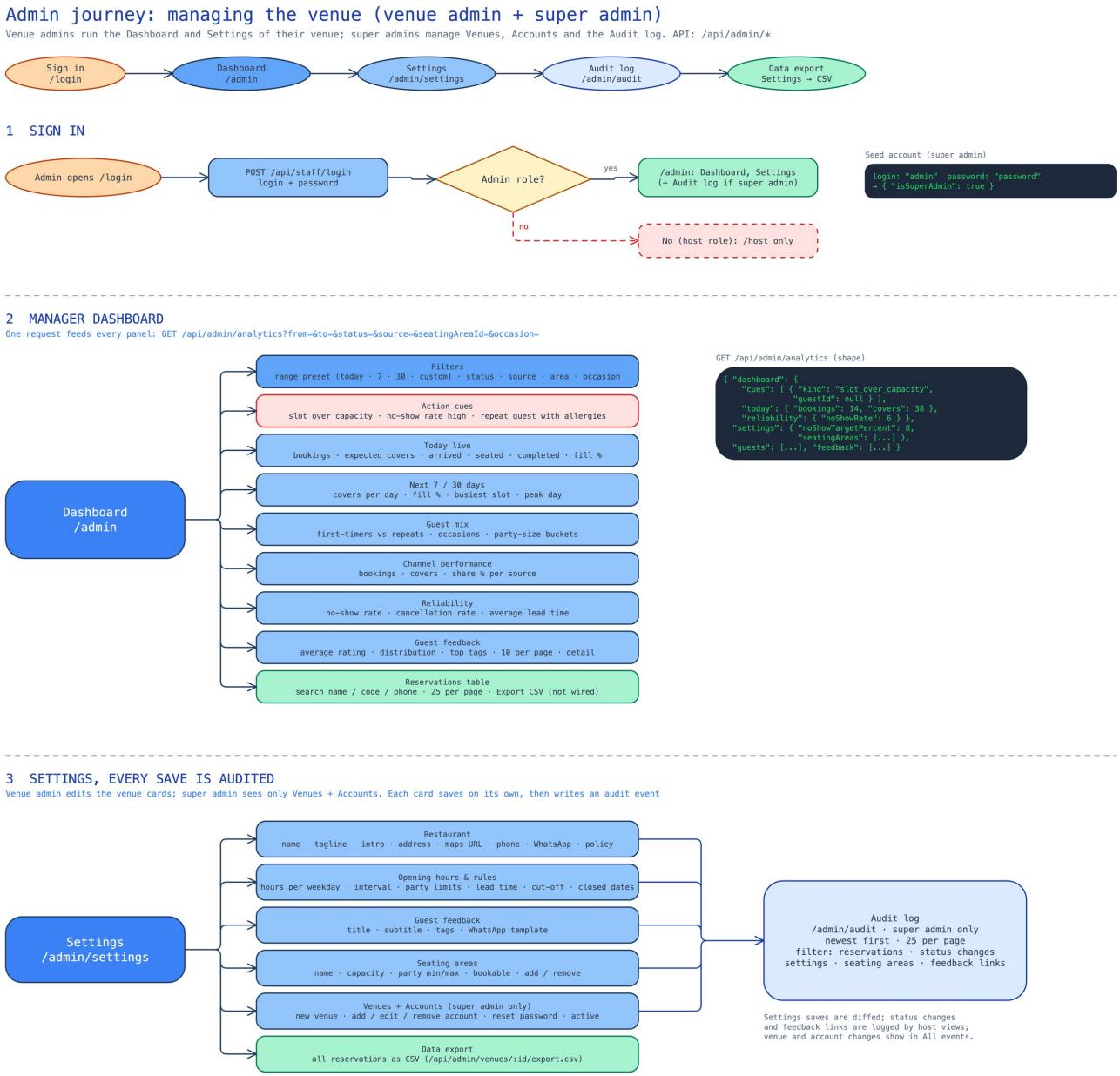
Host journey

Source: docs/diagrams/host-journey.excalidraw. Scenario IDs below map to these stages (see the coverage map).



Admin journey

Source: docs/diagrams/admin-journey.excalidraw. Scenario IDs below map to these stages (see the coverage map).



1. Customer journey (public, no login)

1.1 Discover - `/bali`

ID	P	Scenario	Steps	Expected	Status
G-01	P0	Landing loads	Open `/`	Redirects to `/bali`; hero, experience scenes, visit & hours render; no console errors	Pass
G-02	P1	Visit & hours	Check address, Get directions, WhatsApp, call links, live WITA clock, 7-day opening hours	Values match venue settings; links valid; clock is Asia/Makassar	Pass
G-03	P1	Quick-book -> booking	Choose date (today ... +90 days) and party size, continue	Lands on `/bali/book` with that date/party pre-filled; dates beyond +90 days not selectable	Pass

1.2 Book - `/bali/book`

ID	P	Scenario	Steps	Expected	Status
G-04	P0	Happy path	**1 When** (14-day strip, party stepper, seating) -> time grid -> **2 Who** (name + phone) -> **3 Details** -> accept cancellation policy -> Confirm booking	Redirect to `/bali/confirmation/<code>`; booking is `pending`; shows on `/host`	Pass
G-05	P1	Date strip on mobile	390px viewport	First pill has a left gutter (not flush to the edge); strip scrolls and snaps; "More dates" picker works	Not run
G-06	P1	Time grid states	Look at Lunch / Afternoon / Sunset / Dinner groups across days	Slots show `N left`, `Full`, `Too soon`, or `Closed` correctly; unavailable ones not selectable	Pass
G-07	P1	Closed day / closed date	Pick a closed weekday or a date in Settings -> Closed dates	Pill disabled or all slots `Closed`	Pass
G-08	P0	Capacity (no overbooking)	Fill a slot to capacity from two tabs	Last slot becomes `Full`; API never exceeds capacity	Pass
G-09	P0	**Slot race**	Tab A and B select the same last slot; B confirms first, then A confirms	A sees "That time just filled up"; selected time is cleared; grid refreshes; no booking created for A	Pass
G-10	P1	Party-size bounds	Stepper at `partyMin`/`partyMax`; tamper via API	UI blocks; API 422	Pass
G-11	P1	Lead time and cutoff	Today's slots inside `leadTimeMinutes` / after `cutoffMinutes`	Shown `Too soon` / not offered	Pass
G-12	P1	Required fields	Empty name/phone, malformed phone; email left empty	Inline errors for name/phone; email optional; nothing created	Fail
G-13	P1	Details (optional)	Occasion, dietary, accessibility, notes	Stored; visible on host card and guest profile	Pass

ID	P	Scenario	Steps	Expected	Status
G-14	P1	Policy gate	Try to confirm without accepting the cancellation policy	Blocked	**Pass**
G-15	P1	Idempotency	Double-click Confirm; reload and resubmit	Exactly one reservation, same booking code	**Pass**
G-15b	P1	Turnstile (only if `NUXT_PUBLIC_TURNSTILE_SITE_KEY` set)	Submit without solving	Blocked with message; with token succeeds	**Not run**

1.3 Confirmation - `/bali/confirmation/:code`

ID	P	Scenario	Steps	Expected	Status
G-16	P0	Details + pending state	Land after booking	Shows status `pending`, code, date/time/party/area	**Pass**
G-17	P1	Copy button	Click Copy next to the code	Code in clipboard; feedback shown	**Not run**
G-18	P1	Add to calendar	Click Add to calendar	`.ics` downloads; opens with the right title/time/WITA zone	**Pass**
G-19	P1	Directions / WhatsApp	Click each	Correct maps URL and wa.me number	**Pass**
G-20	P0	No PII on lookup	Open the URL in a fresh browser; call `GET /api/public/reservations/<code>`	No phone/email/internal notes; unknown code -> 404 page	**Pass**
G-21	P1	Cancel (API only)	**Diagram: no cancel button in the web UI yet.** `POST /api/public/reservations/<code>/cancel` for `pending`/`confirmed`; then for `arrived`/`seated`/`completed` and repeat	First -> cancelled (visible on host view); others -> rejected; a second cancel rejected. **If a button was added, add a UI scenario**	**Pass**

1.4 After the visit - `/bali/feedback/:code`

ID	P	Scenario	Steps	Expected	Status
G-22	P1	Only completed	Open feedback for a non-completed booking, submit	Rejected (409)	**Pass**
G-23	P0	Happy path	Complete a booking as host; open the feedback link; rate, pick tags, comment, submit	Saved; thank-you state; appears in Admin -> Guest feedback	**Pass**
G-24	P1	Stars required	Submit with no rating	Blocked (1–5 required)	**Pass**
G-25	P1	Tags offered	Check tag list	Food, Service, Atmosphere, Value (fixed list; the Settings tags field is read-only)	**Not run**
G-26	P1	One feedback per booking	Submit twice	Second rejected	**Pass**

ID	P	Scenario	Steps	Expected	Status
G-27	P1	Unknown code	`/bali/feedback/BADCODE`	Not-found state, no crash	**Pass**

1.5 Public UI

ID	P	Scenario	Steps	Expected	Status
G-28	P2	Theme toggle	Click the theme button	Smooth cross-fade (no per-element flicker); persists on reload; follows OS when unset; reduced-motion = instant	**Not run**
G-29	P2	Theme button vs summary bar	Mobile `/bali/book`	Button sits above the sticky summary	**Not run**
G-30	P1	No staff-login link	Scroll to the landing footer on `/bali`	Footer reads "GIOI Ocean Gourmet · Kuta, Bali" with no "Staff login" link; `/login` still opens by URL	**Pass**

2. Authentication & session

ID	P	Scenario	Steps	Expected	Status
A-01	P0	Host login	`host` / `password`	-> `/host`; nav shows **Host only**; chip "Host User · host"	**Pass**
A-02	P0	Super admin login	`admin`	-> `/admin`; nav Host, Dashboard, Settings, Audit; chip "· super admin"	**Pass**
A-03	P0	Venue admin login	`venueadmin`	-> `/admin`; nav Host, Dashboard, Settings (no Audit)	**Pass**
A-04	P0	Bad credentials	Wrong password / unknown login / inactive user	Same generic error for all; no user enumeration	**Pass**
A-05	P1	Login rate limit	11 wrong attempts, same login + IP, 15 min	11th -> 429 "too many attempts"; correct password also blocked until the window ends; other logins unaffected	**Pass**
A-06	P0	Auth guard	Logged out, open `/host`, `/admin`, `/guests/<id>`	-> `/login`	**Pass**
A-07	P0	**Single device per user**	Profile A logs in as `host`; profile B logs in as `host`	A's next action -> 401 -> `/login?reason=session` with "You were signed out..." banner; B keeps working	**Pass**
A-08	P0	Different users unaffected	A = `host`, B = `admin`	Both stay logged in	**Pass**
A-09	P1	Logout	Sign out	Cookie cleared -> `/login`; Back button shows no data (API 401)	**Pass**
A-10	P1	Expiry / cleared cookie	Delete session row or cookie	Next API call -> 401 -> `/login?reason=session`	**Pass**
A-11	P1	Cookie flags	DevTools -> Cookies	`gioi_session`: HttpOnly, Secure, SameSite=Lax, Path=/	**Pass**

ID	P	Scenario	Steps	Expected	Status
A-12	P1	Deactivated user	Set `active=false` while logged in	Next request 401	**Pass**
A-13	P1	CSRF origin check	With `CORS_ORIGIN` set, POST/PATCH staff routes from a foreign `Origin`	403 "origin not allowed"; same-origin works	**Pass**
A-14	P1	Open redirect	`/login?next=//evil.com` then log in	Stays on this site	**Pass**

3. Role-based access

Expected is shown as **host / venue admin / super admin**.

ID	P	Scenario	Steps	Expected	Status
R-01	P0	`/admin`	Type URL	-> `/host` / loads / loads	**Pass**
R-02	P0	`/admin/settings`	Type URL	-> `/host` / loads / loads	**Pass**
R-03	P0	`/admin/audit`	Type URL	-> `/host` / -> `/host` / loads	**Pass**
R-04	P0	Settings content	Open Settings	- / loads venue sections only (Restaurant, hours, feedback, seating, export), **no Venues/Accounts** / Venues + Accounts only	**Not run** (venue admin Pass, super admin Pass; host not re-run)
R-05	P0	API settings reads (`GET /api/admin/venues/:id`, `/opening-hours`, `/closed-dates`, `/seating-areas`)	DevTools/curl with session cookie	403 / 200 / 200	**Pass**
R-06	P0	API settings writes (PATCH/PUT)	same	403 / 200 / 200	**Pass**
R-07	P0	`/api/admin/analytics`, `/api/admin/venues/:id/export.csv`	same	403 / 200 / 200	**Pass**
R-08	P0	`/api/admin/users`, `/api/admin/venues` (list/create), `/api/admin/audit-log`	same	403 / 403 / 200	**Not run**
R-09	P0	Cross-venue access	Second venue: request its day view / guest / reservation by ID	403 for non-super users	**Pass**
R-10	P1	Front-of-house works for host	Day view, walk-in, edit reservation, status change, guest search/profile	All allowed	**Pass**

ID	P	Scenario	Steps	Expected	Status
R-11	P1	Venue admin can edit reservations	`PATCH /staff/reservations/:id` as `venueadmin`	Allowed (regression: was 403)	**Pass**
R-12	P1	Role change takes effect	Change a role in Settings -> Accounts; log in again	Nav/redirect match the new role	**Pass**
R-13	P1	Dashboard for venue admin	`/admin` as `venueadmin`	Loads; no 403 on audit-log (removed dead fetch)	**Pass**
R-14	P1	Super admin Settings scope	Open Settings as super admin	Only Venues + Accounts cards; no Restaurant, hours, feedback, seating, export (UI only; API would still allow edits)	**Pass**

Diagrams match the code (updated 2026-11-08): venue admins use Dashboard + Settings (not Venues, Accounts or Audit); the super admin Settings page shows only Venues + Accounts and has the Audit log. API `requireRole` still lets a super admin edit venue settings (see Known gaps).

4. Host journey - Today's service (`/host`)

ID	P	Scenario	Steps	Expected	Status
H-01	P0	Day view	Open `/host`	Bookings grouped by time slot; per-group booking count + covers; header "N bookings · M active" correct	**Pass**
H-02	P1	Date navigation	Previous / Today / date picker / Next	List and header date update	**Pass**
H-03	P1	Live refresh	Create a booking from `/bali/book` in another tab	Appears within ~4 s, no reload	**Pass**
H-04	P1	Reservation card content	Inspect a card	Guest (Repeat chip), party, area, code, source, occasion, status chip; alerts for allergies/accessibility/notes	**Not run**
H-05	P0	Status happy path	pending -> confirm -> arrive -> seat -> complete	Each step allowed; chip/counts update; audit event written	**Pass**
H-06	P0	Invalid transitions	Via API: completed->seated, cancelled->confirmed, seated->no_show, same->same	409; UI never offers them	**Pass**
H-07	P1	Cancel / no-show allowed only from	Cancel: pending, confirmed. No-show: confirmed, arrived	Others not offered	**Pass**
H-08	P1	Destructive confirm	Cancel / No-show	Prompt "Mark as X?" with Yes / "Keep booking"; Keep leaves status unchanged	**Pass**
H-09	P1	Final states	completed, cancelled, no_show	No further status buttons	**Pass**
H-10	P0	Open guest from a card	Click guest name	`/guests/<id>` **renders the profile** (regression: wrong route name + missing `serviceTags` crash)	**Pass**

ID	P	Scenario	Steps	Expected	Status
H-11	P1	Feedback link	On a `completed` booking, send feedback link	Opens wa.me link with the template; audited as `feedback_link.sent` (visible in Audit log)	**Pass**
H-12	P1	Empty day	Day with no bookings	"No bookings for this day."	**Pass**
H-13	P2	Tabs	Today's service ↔ Guest search	Content swaps; no console errors	**Pass**

4.1 Walk-in modal

ID	P	Scenario	Steps	Expected	Status
W-01	P0	Create walk-in	"+ Walk-in": name, phone, party, time, area, source, occasion, allergies, notes	Created; **auto-confirmed** (status `confirmed`, not `pending`); appears in the list	**Pass**
W-02	P1	Date fixed to today	Inspect the modal	Date is always today; no date picker	**Pass**
W-03	P1	Required fields	Empty name/phone	Inline error; nothing created	**Not run**
W-04	P0	Capacity checked	Walk-in into a full slot/area	Rejected with message (409/422); no overbook	**Pass**
W-05	P1	Hours checked	Time outside opening hours	Rejected	**Pass**
W-06	P1	Past / lead-time rules skipped	Walk-in for a time in the past or inside lead time	Allowed (diagram: these rules are skipped for walk-ins)	**Pass**

5. Host journey - Guests (`/host` tab + `/guests/:id`)

ID	P	Scenario	Steps	Expected	Status
S-01	P0	Search finds any guest	Type `me` (guest "Mega Putri" is not in the first 8 alphabetically)	Listed with phone, `N visits`, badges	**Pass**
S-02	P1	Search fields	Name fragment, phone digits, email fragment	All match, case-insensitive	**Pass**
S-03	P1	Min length	0–1 chars	"Type at least 2 characters."; no request	**Pass**
S-04	P1	Max 8 results	Query matching >8 guests	8 rows	**Pass**
S-05	P1	No results	`zzzzz`	"No guests match."	**Pass**
S-06	P1	Fast typing	Type quickly then change query	Debounced; final list matches final query	**Pass**
S-07	P0	Profile renders	Click a result	`/guests/<id>`: contact, allergies, seating preference, internal notes, visits/cancelled/no-show counts, visit history	**Pass**
S-08	P1	Visit feedback	Visit with feedback	"Guest feedback: x/5", comment, "Stood out: ..."	**Pass**

ID	P	Scenario	Steps	Expected	Status
S-09	P1	Profile is read-only	Look for edit controls	None	**Pass**
S-10	P1	Back button	host -> guest -> Back; admin -> guest -> Back; direct URL -> Back	Returns to origin; direct load falls back to `/host` (host) or `/admin` (admin)	**Pass**
S-11	P1	Visit pagination	Guest with >10 visits	10/page, Previous/Next, "Page x of y"	**Not run**
S-12	P0	Other venue's guest	`/guests/<id from another venue>` as host	No data (403 / not found)	**Pass**
S-13	P1	Unknown id	`/guests/00000000-0000-0000-0000-000000000000`	"Guest not found."	**Pass**

6. Admin journey - Dashboard (`/admin`)

ID	P	Scenario	Steps	Expected	Status
D-01	P0	Loads	Open as admin	All panels render; no console errors	**Pass**
D-02	P1	Range presets	today / 7 / 30 / custom	Numbers + labels update; custom range validated	**Pass**
D-03	P1	Filters	status, source, area, occasion	Panels respect them (one request: `/api/admin/analytics?from&to&...`)	**Pass**
D-04	P1	Action cues	Slot over capacity, no-show rate high, repeat guest with allergies	Cue appears when its condition is met; "Open guest ->" / "Open host view ->" go to the right place	**Pass**
D-05	P1	Today live	Bookings, expected covers, arrived, seated, completed, fill %	Match `/host`	**Pass**
D-06	P1	Next 7 / 30 days	covers/day, fill %, busiest slot, peak day	Plausible vs seeded data	**Pass**
D-07	P1	Guest mix, channels, reliability	first-timers vs repeats, occasions, party buckets; channel share %; no-show %, cancel %, avg lead time	No NaN / undefined; totals add up	**Pass**
D-08	P1	Guest feedback panel	avg rating, distribution, top tags, latest	Matches submitted feedback; 10 per page with Previous/Next; click opens detail modal (Esc closes)	**Pass**
D-09	P1	Reservations table search	name / code / phone	Filters; "N matching" updates	**Pass**
D-10	P1	Reservations pagination	>25 matches	25/page (was "first 50"); shrinking results clamps the page	**Pass**
D-11	P1	Export CSV button	Click in the table header	Currently rendered without a handler - verify intent (use Settings -> Data export)	**Fail**
D-12	P2	Empty range	Range with no data	Empty states, no NaN	**Pass**
D-13	P1	New venue, no data	Dashboard on a venue with zero reservations	Zeros/empty states; no NaN, no "Invalid Date", no 500	**Pass** (found + fixed: "peak 0 on Invalid Date")

ID	P	Scenario	Steps	Expected	Status
D-14	P1	API down on dashboard	Stop the API, reload `/admin`	The real error message shows (not "Invalid date range"); no crash	**Not run**

7. Admin journey - Settings (`/admin/settings`, every save audited)

ID	P	Scenario	Steps	Expected	Status
T-01	P0	Load	Open as venue admin and super admin	Venue admin: venue cards. Super admin: Venues + Accounts cards only	**Pass**
T-02	P0	**Restaurant**	Edit tagline/intro/address/maps URL/phone/WhatsApp/policy -> Save	"Saved at ..."; persists; shown on `/bali`; audit event	**Pass**
T-03	P1	Name read-only	Restaurant name	Disabled (not in the API whitelist)	**Pass**
T-04	P1	**Opening hours & rules**	Hours per weekday, interval, party limits, lead time, cut-off, closed dates	Public availability follows each	**Pass**
T-05	P1	**Guest feedback**	Title, subtitle, WhatsApp template (tags field is read-only)	Used on feedback page and the host's feedback link	**Pass**
T-06	P1	**Seating areas**	Name, capacity, party min/max, bookable, add/remove	Public + walk-in options follow	**Pass**
T-07	P1	**Accounts** (super admin)	See 7.1 (T-13...T-28)	Replaced by the Venues/Accounts scenarios	**Pass**
T-08	P0	**Data export**	Download reservations CSV	File downloads with guest contact + allergy/accessibility notes; 403 for hosts	**Pass**
T-09	P1	Save is diffed	Change one field, save	Audit event lists only the changed field(s)	**Pass**
T-10	P1	Failed save	Stop the API, Save	"Save failed..." message, no silent success	**Not run**
T-11	P1	Concurrent edit	Two tabs edit the same card	Last save wins; no crash; no stale data after reload	**Not run**
T-12	P2	Validation	Negative capacity, min > max, bad time ranges	Rejected with a clear message	**Pass**

7.1 Super admin: venues and accounts (Settings -> Venues / Accounts)

ID	P	Scenario	Steps	Expected	Status
T-13	P0	Create venue	Venues -> name + slug -> Create venue	Appears selected in the picker; audit `venue.created`; blank details for its admin to fill	**Pass** (audit entry not checked in the UI)
T-14	P1	Slug rules	Uppercase, spaces, duplicate slug	Rejected with a clear message (400 pattern / 409 "venue slug already exists"); nothing created	**Pass**

ID	P	Scenario	Steps	Expected	Status
T-15	P1	Switch venue	Pick another venue in the picker	Accounts list reloads for that venue only	**Pass**
T-16	P0	Add account	Accounts -> name, login, password (12+), role -> Add account	Listed; user can log in; lands on `/admin` (admin) or `/host` (host); sees only that venue	**Not run** (admin Pass lands `/admin`; host login Pass via API; host landing page and venue isolation not run)
T-17	P1	Login rules	Duplicate login; login typed with capitals/spaces	409 "login already exists"; stored trimmed + lowercase; login form accepts any case	**Pass**
T-18	P1	Password length	Password under 12 chars	Blocked in the form; API 400	**Pass** (form; API 400 seen in the earlier curl run)
T-19	P1	Edit account	Change name, login, role -> Save accounts	Persists; role effective on next login; audit event	**Not run** (name + login Pass; role change and audit entry not checked)
T-20	P0	Reset password	Type a new password -> Save accounts	New password works, old fails; that user's open sessions get 401; blank field keeps the old password	**Pass**
T-21	P1	Deactivate	Untick Active -> Save	User signed out on next request; cannot log in	**Pass**
T-22	P0	Remove	Remove -> confirm; also test Cancel on the prompt	Cancel changes nothing; confirm removes from the list; user with no other venue cannot log in; audit `user.removed`	**Pass** (audit entry not checked in the UI)
T-23	P1	Super admin hidden	Look at the Accounts list	The super admin's own row is not listed	**Pass**
T-24	P1	Empty states	No venues; venue with no accounts	Picker disabled and no Accounts card; "No admin or host accounts for this venue yet."	**Not run** (no-accounts half Pass; zero-venue state not run)
T-25	P0	API authorization	As host / venue admin / logged out: `GET/POST /api/admin/venues`, `POST/PUT /api/admin/users`, `DELETE /api/admin/users/:id?venueId=`	403 / 403 / 401; `DELETE` on a super admin id -> 404; bad UUID -> 400	**Pass**
T-26	P0	Venue admin first run	Log in as the new venue admin on a blank venue	Settings loads; fill Restaurant, hours, seating areas; saved; `/<slug>` shows them; multi-venue isolation holds (R-09)	**Pass** (Restaurant only; hours/seating not filled)
T-27	P1	No spaces in logins	Create or edit a login containing a space, or only spaces	422 "login must not contain spaces"; leading/trailing spaces are trimmed	**Pass**
T-28	P1	Rename to an existing login	Edit an account's login to another user's login -> Save	409 "login already exists" (was a 500); renaming to its own login is a no-op	**Pass**

8. Audit log (`/admin/audit`, super admin)

ID	P	Scenario	Steps	Expected	Status
L-01	P1	Events recorded	Status change, settings save, users save, feedback link sent, seating-area change, venue created, user created, user removed	One event each with actor, entity, changed fields, time; check whether the entity filter (L-03) lists the new `venue.created` / `user.created` / `user.removed` types	Not run
L-02	P1	Newest first	Inspect order	Newest at top	Pass
L-03	P1	Filter	Entity dropdown: reservations / status changes / settings / seating areas / feedback links	List narrows; page clamps	Pass
L-04	P1	Pagination	>25 events	25/page, Previous/Next	Pass
L-05	P1	Empty state	Fresh DB	Friendly message	Not run
L-06	P0	Access	Host / venue admin	Redirect + API 403	Pass

9. UI / cross-cutting

ID	P	Scenario	Steps	Expected	Status
U-01	P1	Staff theme toggle	host/admin pages	Smooth cross-fade incl. header; persisted; staff default dark when unset	Pass
U-02	P1	Responsive	390 / 768 / 1280 on every page	No unintended horizontal overflow; mobile nav is a second row; tap targets >= 44 px	Not run
U-03	P1	Keyboard	Tab through login, booking, host list, modals	Visible focus, logical order, Esc closes modals	Not run
U-04	P2	Reduced motion	OS setting on	Theme switch and transitions instant/fade only	Not run
U-05	P1	Console clean	Walk every page	No uncaught errors/hydration warnings	Fail
U-06	P1	API down	Kill API mid-session	Error states, not a blank page or endless "Loading..."	Not run
U-07	P1	Host-based routing	`book.*` host -> staff routes 404; `admin.*` host -> guest routes 404	As in `server/middleware/host-routes.ts`	Pass
U-08	P2	Time zone	Booking near midnight (Asia/Makassar)	Same date/time on confirmation, host, admin, `.ics`	Pass

10. Security smoke (browser DevTools / curl)

ID	P	Check	Expected	Status
X-01	P0	Every `/api/staff/*` and `/api/admin/*` call with no cookie	401	Pass
X-02	P0	Replay an old cookie after logging in elsewhere	401	Pass
X-03	P0	Public booking lookup response	No phone/email/internal notes	Pass

ID	P	Check	Expected	Status
X-04	P1	XSS: guest name/notes `<img src=x onerror=alert(1)>`	Rendered as text on host, profile, admin, audit	**Pass**
X-05	P1	SQL-ish search `' OR 1=1 --`	Treated literally	**Pass**
X-06	P1	Tamper UUIDs (reservation/guest/venue from another venue)	403/404 only	**Pass**
X-07	P1	Garbage or oversized bodies to public booking	4xx, never 500	**Pass**
X-08	P1	Error shape / headers	`{ error, message }`; no stack traces	**Pass**

11. Bootstrap, production and CI

ID	P	Scenario	Steps	Expected	Status
B-01	P0	Venue-only bootstrap	`DATABASE_URL=... ADMIN_LOGIN=admin npx tsx prisma/create-super-admin.ts` (no `ADMIN_PASSWORD`) on a DB with an admin and no venue	Prints `super admin ready: admin, venue: bali`; admin password unchanged; `GET /api/public/venues/bali` 200; safe to run twice	**Pass** (local DB)
B-02	P1	Bootstrap guards	Unknown `ADMIN_LOGIN` without password; `ADMIN_PASSWORD` shorter than 12	Stops with a clear error; nothing written	**Not run**
B-03	P0	No venue yet (prod symptom)	Log in as super admin on a DB with no venue	Host day and Dashboard show empty data or a real error message (not 403 / "Invalid date range"); Settings shows Venues + "create venue", not a blank page	**Not run** (empty-venue half Pass as venue admin; zero-venue DB not run)
B-04	P1	Re-login after bootstrap	Run the script while logged in, reload	Venue links appear only after logging in again (session holds old venue list)	**Not run**
B-05	P1	Empty-venue public page	Open `/<slug>` for a venue with blank address/phone/hours	Page renders without crash; missing values degrade gracefully	**Pass**
B-06	P1	CI	Push to a PR	Setup pnpm (no version conflict), install, prisma generate/validate without `.env`, `nuxt prepare`, typecheck, tests all green	**Not run** (steps Pass locally; GitHub run pending)

Known gaps worth a ticket (not scenarios)

- Guest cancel exists only as an API; no button on the confirmation page (per customer diagram).
- Dashboard "Export CSV" button has no handler.
- Login rate limiting is in-memory per serverless instance; needs a shared store for real brute-force protection.
- Sessions have a fixed 7-day life (no sliding expiry).
- Pagination is client-side; only the audit endpoint accepts `limit`.
- Settings hides venue sections from the super admin in the UI only; the API still lets a super admin edit venue settings.

- No hard delete of users: "Remove" unlinks from the venue and deactivates when no venue is left (audit rows reference users).
- No venue rename/delete, and no email field in Settings (email is only set at bootstrap/seed).
- Super admin's own Host/Dashboard use the first linked venue only; no venue switcher there.
- Public staff-login link was removed from the landing footer; `/login` is reachable by URL only.

Run notes (2026-11-07, managed Chromium + curl, dev DB)

- Fail **D-11** Export CSV button in the dashboard table has no handler (use Settings -> Data export).
- Fail **G-12** Confirm is disabled until name/phone are valid; there are no inline error messages.
- Fail **U-05** Dev-only `Hydration completed but contains mismatches` on `/bali` (cause not isolated).
- Not run not run: G-05, G-15b (no Turnstile key), G-17, G-28, G-29, H-04, L-05, S-11 (no guest with >10 visits), T-10, T-11, U-02 (no overflow at 390/768/1280; tap-target count not reviewed), U-03, U-04, U-06 (API down: pages show "Venue not found." / "couldn't find that booking code" instead of an unavailable state).
- A-13 verified on a temp API with `CORS_ORIGIN` set: foreign Origin -> 403, same origin -> 200.

Run notes (2026-11-07, later: venues/accounts, localhost browser run)

Managed Chromium (the user's Chrome relay was unusable: the relay on :9224 and this OMP session were different versions) against local web `:3000` + local API `:3001` + dev DB. Accounts and venues created by the run (`qa-mw6ffk7e`, `qava...`) remain in the dev DB, deactivated where possible (audit rows block deleting them). No prod access.

- Pass run in the browser: G-30, R-04 (venue admin + super admin), R-14, T-01, T-07, T-13 to T-17 (dup login 409 shown in the UI), T-18, T-20 to T-23, D-13, B-05.
- Pass run through the API: T-25 (host / venue admin / anon / super admin edge cases), T-27, T-28.
- Not run partial or not run: T-16 (host landing page, venue isolation), T-19 (role change, audit entry), T-24 (zero-venue state), T-26 (hours and seating not filled), D-14, B-02 (password-length guard), B-03 (zero-venue DB), B-04, B-06 (GitHub run), L-01 (audit entries for `venue.created` / `user.created` / `user.removed` not viewed in the Audit page), R-08 (`/api/admin/audit-log` not re-run).
- **Found and fixed during this run:**

- D-13: the new-venue dashboard showed "peak 0 on Invalid Date" (empty peak date). The peak is now shown only when there is one.

- T-27: logins with spaces inside were accepted (`qaadminm qahostr...`). They now return 422.

- T-28: renaming a login to an existing one returned 500. It now returns 409.

- **Behaviour to remember when testing:** logging in as a user through the API replaces that user's browser session (single device per user, A-07). Use a separate user, or log in again after API calls.